DOCUMENT OFFICIEL — ÉDITION 2026 — VALIDITÉ 3 ANS

Caméléons RH 2026

Sécurité de l'Information — Tiers

Programme de Diligence Raisonnable

Document complémentaire à la **Procédure d'Alerte Sécurité Info 2026**

PRÉFACE

Engagement de la Direction

Caméléons RH partage des données sensibles avec un nombre restreint de tiers : **paie, banques, assurances santé et prévoyance, médecine du travail, plateformes de dématérialisation**. La sécurité de ces flux d'information conditionne directement la confiance accordée par nos candidats, intérimaires et clients.

Le présent programme formalise les contrôles que la Direction met en œuvre pour s'assurer que chaque tiers respecte nos exigences de sécurité. Il s'inscrit en cohérence avec la Procédure d'Alerte Sécurité de l'Information 2026 et complète le dispositif global de protection des données.

> « La sécurité de nos données ne s'arrête pas à nos murs. Chaque tiers qui y accède est partie intégrante de notre dispositif de protection. »
> *[Nom du DG] — Président, CAMELEON COM MARK SASU — Avril 2026*

Compte tenu de la taille de la structure (7 collaborateurs permanents) et du nombre limité de tiers critiques, la diligence est conduite **directement par la Direction**, garantissant proximité et contrôle effectif.

CHAPITRE 1

Cadre de Référence Réglementaire

Le présent programme s'inscrit dans le cadre des textes et standards suivants. Chaque référentiel apporte une exigence complémentaire qui structure notre approche de la diligence raisonnable envers les tiers.

RGPD — (UE) 2016/679

Obligation pour le responsable de traitement de s'assurer que ses sous-traitants présentent des garanties suffisantes (Article 28). Notification CNIL sous 72 heures en cas de violation.

Loi Informatique et Libertés — n° 78-17

Cadre national qui complète le RGPD pour les traitements relevant du droit français. Applicable à l'ensemble de nos sous-traitants établis en France.

Loi Sapin II — n° 2016-1691

Diligence raisonnable étendue aux tiers en matière de prévention des risques, notamment éthiques et de corruption.

ISO 27001 & 27002

Standards internationaux de management de la sécurité de l'information, utilisés comme référence principale d'évaluation des tiers.

SOC 2 Type II

Standard américain de contrôle des prestataires de services, souvent appliqué par les banques et services cloud traçant des données sensibles.

HDS — Hébergeur de Données de Santé

Certification française obligatoire pour tout prestataire manipulant des données de santé. S'applique notamment à Swiss Life et CIAMT.

CHAPITRE 2

Périmètre et Cartographie des Tiers Concernés

Sont concernés tous les tiers ayant un accès direct ou indirect à des données personnelles ou à des systèmes d'information de Caméléons RH.

Cartographie 2025 — 15 tiers évalués

Tiers en criticité Haute (12)

Tiers	Catégorie de données traitées	Cadre réglementaire applicable
Enso	Données personnelles salariés et intérimaires (paie, contrats)	RGPD + ISO 26000 (RSE)
Microsoft	Emails, documents, accès cloud (Office 365, Azure)	RGPD + ISO 27001 + SOC 2
Pixid	Plateforme de dématérialisation contrats et paie intérimaires	RGPD + ISO 27001 + SOC 2
Onesyss	Plateforme de dématérialisation RH	RGPD
CIC	Flux financiers, RIB salariés	RGPD + ACPR + BCE
Société Générale	Flux financiers, RIB salariés	RGPD + ACPR + BCE
Banque Populaire	Flux financiers, RIB salariés	RGPD + ACPR + BCE
Swiss Life	Données de santé (prévoyance) et flux financiers RIB salariés	RGPD + ACPR + HDS
Allianz	Données assurance entreprise et salariés	RGPD + ACPR
AXA	Données assurance entreprise et salariés	RGPD + ACPR
Atradius	Garantie financière intérimaires, données contractuelles	RGPD + ACPR
CIAMT	Données de santé (visites médicales)	RGPD + HDS

Tiers en criticité Moyenne (3)

Tiers	Catégorie de données traitées	Cadre réglementaire applicable
AKTO	Données salariés (formation professionnelle)	RGPD + France Compétences
FASTT	Données intérimaires (action sociale)	RGPD
Swile	Données salariés (titres-restaurant)	RGPD + agrément CRT

Cartographie établie en avril 2026. Revue annuelle par la Direction. Toute évolution significative entraîne une mise à jour immédiate.

CHAPITRE 3

Grille d'Évaluation Sécurité — 5 Critères

Chaque tiers est évalué **annuellement** sur 5 critères techniques. Cette grille structurée permet une évaluation objective, documentée et comparable d'une année sur l'autre.

Critère	Ce qui est évalué	Source de preuve
1. Certifications	ISO 27001, SOC 2, HDS si applicable	Certificat à jour, organisme délivrant
2. Conformité RGPD	Politique de confidentialité, registre des traitements, DPO	Politique RGPD et accord de sous-traitance Art. 28
3. Gestion des accès	MFA, chiffrement des données, contrôle d'accès basé rôles	Description technique et audit interne du tiers
4. Plan de réponse aux incidents	Procédure documentée, délai de notification, point de contact	Plan transmis et tests réalisés
5. Historique de conformité	Incidents passés, sanctions CNIL, mesures correctives	Recherche publique et déclaration sur l'honneur

Échelle de notation

✅ Conforme

Respecte intégralement le critère — preuves documentées disponibles.

⚠️ À améliorer

Conformité partielle — un plan d'action formalisé est requis sous délai défini.

🚫 Non conforme

Manquement majeur — action immédiate exigée, résiliation envisageable.

CHAPITRE 4

Résultats de l'Évaluation Sécurité — Exercice 2025

L'évaluation 2025 a été conduite par la Direction sur les **15 tiers évalués**.

13

Tiers Conformes

sur 15 évalués — résultat solide pour l'exercice 2025.

2

Plans d'actions

Onesyss et CIAMT — délais définis et suivis.

0

Non conformes

Aucun manquement grave constaté sur l'exercice.

Détail — Tiers en criticité Haute

Tiers	Conformité réglementaire	RGPD	Accès	Incidents	Historique	Note
EnSO Group	ISO 26000 + EcoVadis Silver 2025	Conforme	Conforme	Conforme	Conforme	**Conforme**
Microsoft	ISO 27001 + SOC 2 + ISO 27018	Conforme	Conforme	Conforme	Conforme	**Conforme**
Pixid	ISO 27001 + SOC 2	Conforme	Conforme	Conforme	Conforme	**Conforme**
Onesyss	RGPD documenté	Conforme	À améliorer	Conforme	Conforme	**À améliorer**
CIC	ACPR + BCE	Conforme	Conforme	Conforme	Conforme	**Conforme**
Société Générale	ACPR + BCE	Conforme	Conforme	Conforme	Conforme	**Conforme**
Banque Populaire	ACPR + BCE	Conforme	Conforme	Conforme	Conforme	**Conforme**
Swiss Life	ACPR + HDS	Conforme	Conforme	Conforme	Conforme	**Conforme**
Allianz	ACPR	Conforme	Conforme	Conforme	Conforme	**Conforme**
AXA	ACPR	Conforme	Conforme	Conforme	Conforme	**Conforme**
Atradius	ACPR	Conforme	Conforme	Conforme	Conforme	**Conforme**
CIAMT	HDS	Conforme	À améliorer	Conforme	Conforme	**À améliorer**

Détail — Tiers en criticité Moyenne

Tiers	Conformité réglementaire	RGPD	Accès	Incidents	Historique	Note
AKTO	France Compétences	Conforme	Conforme	Conforme	Conforme	**Conforme**
FASTT	RGPD documenté	Conforme	Conforme	Conforme	Conforme	**Conforme**
Swile	Agrément CRT	Conforme	Conforme	Conforme	Conforme	**Conforme**

Plans d'actions correctives 2025

CIAMT — Gestion des accès

Action corrective demandée pour fournir un descriptif détaillé du **chiffrement utilisé lors de la transmission des dossiers médicaux**. Délai accordé : 6 mois. Plan d'action documenté et suivi par la Direction.

Onesyss — Gestion des accès

Action corrective demandée pour formaliser la **procédure de revue trimestrielle des comptes utilisateurs** et la suppression des comptes inactifs. Délai accordé : 3 mois. Plan d'action documenté et suivi par la Direction.

Synthèse 2025 : 13 tiers Conformes sur 15. 2 tiers en plan d'actions documenté. Aucun Non conforme. Évaluation conduite par la Direction en avril 2026. Prochaine revue : avril 2027.

CHAPITRE 5

Procédure de Suivi et Audit

La procédure de suivi s'articule en **5 étapes structurées**, de l'entrée en relation avec un nouveau tiers jusqu'à l'archivage des documents. Elle garantit la traçabilité et la continuité du contrôle dans le temps.

01

Évaluation initiale (entrée en relation)

- Vérification des certifications de sécurité du tiers
- Signature d'un accord de sous-traitance RGPD (Article 28)
- Demande de la politique de sécurité du tiers
- Évaluation initiale sur les 5 critères de la grille

02

Revue annuelle (avril)

- Mise à jour de la cartographie des tiers
- Renvoi du questionnaire de sécurité
- Vérification de la validité des certifications
- Revue des incidents éventuels survenus dans l'année

03

Audit ponctuel

- Déclenché en cas de doute, d'incident ou de changement significatif
- Pour Swiss Life et CIAMT (données de santé) : audit a minima tous les 2 ans

04

Plan d'actions correctives

- Notification écrite du manquement constaté
- Délai défini selon la gravité (1 à 6 mois)
- Suivi à 3 mois — vérification à 6 mois
- Résiliation possible en cas de non-respect des engagements

05

Documentation et archivage

- Tous les rapports et plans d'actions archivés par la Direction
- Durée minimale de conservation : 5 ans

CHAPITRE 6

Sanctions et Reporting

Le dispositif de sanctions garantit une réponse proportionnée à la gravité de chaque manquement. Les indicateurs de suivi permettent à la Direction de piloter l'efficacité du programme et d'en rendre compte de façon transparente.

Niveaux de sanctions en cas de manquement

Niveau	Action
Manquement mineur	Notification écrite + plan correctif sous 6 mois
Manquement caractérisé	Mise en demeure + audit ciblé + plan correctif sous 3 mois
Manquement grave / récidive	Résiliation immédiate + signalement CNIL si données personnelles concernées

Indicateurs de suivi — Exercice 2025

Tiers évalués (Haute et Moyenne criticité)	**15**
Tiers Conformes	**13**
Tiers en plan d'actions correctives	**2**
Tiers Non conformes	**0**
Incidents sécurité tiers signalés	**0**
Notifications CNIL effectuées	**0**
Dernière revue de cartographie	**Avril 2026**

Bilan 2025

Aucun incident de sécurité de l'information impliquant un tiers n'a été recensé sur l'exercice 2025. Le taux de conformité atteint **87 %** (13/15), avec deux plans d'actions en cours de déploiement dans les délais impartis.

Prochaine revue complète : **avril 2027**.

VALIDATION OFFICIELLE

Validation et Engagement de la Direction

Le présent Programme de Diligence Raisonnable sur la Sécurité de l'Information pour les Tiers a été adopté par la Direction de **CAMELEON COM MARK SASU** et entre en vigueur à compter de sa date de signature. Il complète la Procédure d'Alerte Sécurité de l'Information 2026 et fait l'objet d'une **revue annuelle**.

> Je soussigné(e) **[Nom DG]**, Président de CAMELEON COM MARK SASU, certifie avoir pris connaissance du présent programme et m'engage à en respecter et faire respecter toutes les dispositions dans la conduite des relations avec les tiers de l'entreprise.
>
> À [Ville], le [date]
>
> _____
> *[Nom DG] — Président, CAMELEON COM MARK SASU*

📅 Version

Édition 2026

🔄 Prochaine révision

Avril 2027

🗂️ Conservation

Archives 5 ans

🔒 Diffusion

Document interne